



DAS Policy

Multifactor Authentication

No:
2100-14

Effective:
April 29, 2025

Approval: 
Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to provide **Multifactor Authentication (MFA)** requirements to Ohio Department of Administrative Services (DAS) technical teams that will allow for the consistent implementation of MFA across **DAS-Managed System Assets**. The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

The scope of this policy includes all DAS-Managed System Assets that require MFA. This policy outlines the minimum acceptable criteria governing MFA implementations.

III. Policy

DAS system and service owners shall work with DAS business owners to conduct risk assessments and data classification exercises on DAS-Managed System Assets in accordance with Ohio Administrative Policy IT-13, "Data Classification," and DAS Policy 2100-08, "Risk Assessment." MFA shall be applied to systems based on the outcome of those assessments and in accordance with the requirements of this policy. The policy sections below detail when MFA is required or optional.

A. **Required MFA for DAS-Managed System Assets (for Organizational Users):** The use of MFA shall be required for **Organizational Users** under the following conditions:

1. When **User IDs** are assigned **Privileged** access
2. When **Remote Access** is granted

- B. **MFA for DAS-Managed System Assets (for Organizational Users):** MFA shall be used as a mitigating control and is recommended for Organizational Users when indicated by the results of a risk assessment. The following conditions are examples of higher-risk scenarios where MFA should be considered:
1. When the information system contains **Confidential Data**, such as federal tax information (FTI), **Personally Identifiable Information (PII)**, and protected health information (PHI).
 2. When high-risk factors, such as the following, are involved:
 - a) Internet Protocol (IP) Reputation – restrict access from untrusted IP addresses.
 - b) Geolocation – only allow access from certain geographic locations.
 - c) Transaction-based – only when certain high-risk transactions (e.g., financial or administrative) are attempted.
- C. **Two-Step Authentication (for Non-Organizational Users):** **Two-Step Authentication** shall not be used in place of MFA. However, the use of Two-Step Authentication is acceptable for **Non-Organizational Users** as a mitigating control when risk assessment results indicate that there is a need for authentication stronger than single factor.
- D. **Exception Process:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
1. The form is located within the IT Enterprise Services Portal under the “Services & Products” category.
 2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. **Confidential Data.** This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.
- B. **DAS-Managed System Asset.** Information, hardware, software and services required to support state business, and identified during the risk assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.

- C. Multifactor Authentication. Authentication using two or more factors to achieve authentication. Factors include: (i) something you know (e.g., password/PIN); (ii) something you have (e.g., cryptographic identification device, token); or (iii) something you are (e.g., biometric).¹
- D. Non-Organizational User. A user who is not an Organizational User², which for the purposes of this policy includes public users.
- E. Organizational User. An Organizational User is anyone who is an employee of the state, or is otherwise authorized to work on behalf of the State, and who has a need to access State of Ohio IT systems and has secured agency authorization for such access. The organizational identifier will help to distinguish the individual during the authentication process. Examples of resources that may fall into this category include full-time employees, part-time employees, seasonal employees, temporary contract workers, independent contractors or consultants, volunteers or unpaid interns. The Organizational User identifier category may also include university and federal government resources.
- F. Personally Identifiable Information. “Personally Identifiable Information” is information that can be used directly or in combination with other information to identify a particular individual. It includes:
 - 1. a name, identifying number, symbol, or other identifier assigned to a person,
 - 2. any information that describes anything about a person,
 - 3. any information that indicates actions done by or to a person,
 - 4. any information that indicates that a person possesses certain personal characteristics.³
- G. Privileged User. A user that is authorized (and, therefore, trusted) to perform system and application functions that ordinary users are not authorized to perform.³
- H. Remote Access. Access to an organizational information system by a user (or an information system acting on behalf of a user) communicating through an external network (e.g., the Internet).⁴
- I. Two-step Authentication: Two-step Authentication provides an additional layer of security over single-factor authentication (providing something the user knows such as a User ID and password). It requires the user to also provide something they have, which is typically a personal identification number (PIN). Most commonly, the user supplies additional contact information for the PIN during the registration process. The PIN can be delivered by email, phone callback, or short message service (SMS) text. Two-Step Authentication is generally used with Non-Organizational Users.

¹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations, Initial Public Draft,” U.S. Department of Commerce National Institute of Standards and Technology, April 2013, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

³ Based on Ohio Revised Code Section 1347.01 (E).

- J. User ID: Unique symbol or character string used by an information system to identify a specific user.⁴

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
IRS Publication 1075, Tax Information Security Guidelines for Federal, State and Local Agencies	https://www.irs.gov/pub/irs-pdf/p1075.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies
DAS-ITS-2100-01-A Password Standard for Organizational Users	https://das.ohio.gov/technology-and-strategy/policies
DAS-ITS-2100-01-B Password Standard for Non- Organizational Users	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor

⁴ “CNSS Instruction No. 4009, National Information Assurance (IA) Glossary,” Committee on National Security Systems, 6 April 2010 <<https://www.hsdn.org/?abstract&did=7447>>.

Columbus, Ohio 43215
614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/22/2017	Original Policy
11/26/2018	Updated the exception request language to align with the current procedure.
02/26/2020	Updated the policy template to align with the current format.
09/30/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data.